

Social Engineering

IT-SICHERHEIT / SEMESTER 1 UND 2



1

AGENDA

- 01 DEFINITION VON SOCIAL-ENGINEERING-ANGRIFFEN
- 02 (TECHNISCHE) SOCIAL ENGINEERING ABWEHR
- 03 SOCIAL ENGINEERING AWARENESS
- 04 ÜBUNG

2

IT-SICHERHEIT / SEMESTER 1 UND 2

Be Savvy About the Social Engineer



tgm

[Quelle: <https://www.npsa.gov.uk/security-campaign-assets/social-engineering-assets> –
letzter Abruf 29.10.2025]]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

3

3

01

Definition von Social-Engineering-Angriffen

4

Was sind "personenbezogene Daten"?

Personenbezogene Informationen oder "personenbezogene Daten" bedeuten:

„Informationen, die verwendet werden können, um die Identität einer Person zu unterscheiden oder zurückzuverfolgen, entweder allein oder in Kombination mit anderen Informationen, die mit einer bestimmten Person verknüpft oder verknüpfbar sind.“

5

Social Engineering

- Für Angriffe auf die IT wird **nicht immer Technologie benötigt**
- Social Engineering **sammelt Informationen**, indem es sich auf die **Schwächen von Einzelpersonen** stützt
- Es stützt sich auf **psychologische Ansätze**, um ein Opfer zu überzeugen

Niemand ist immun

Viele kluge und umsichtige Menschen können Opfer eines Social-Engineering-Angriffs werden, ohne es zu merken, bis es zu spät ist.

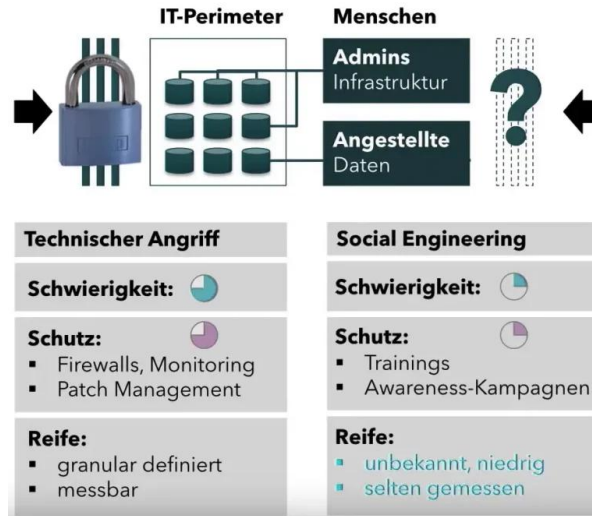
Wachsamkeit und gesunder Menschenverstand sind der Schlüssel zum Schutz

Worauf haben sie es abgesehen?

- **Finanziellen Gewinn** erzielen.
- **Persönliche Rache**, um einen Standpunkt zu beweisen,
- **Persönliches Vergnügen oder Langeweile** heraus.
- Durch Social Engineering könnte ein Hacker viele Dinge mit Finanz- oder Kontoinformationen anstellen.
 - aus ihren **Konten aussperren**
 - ihre **Daten verkaufen**
 - das **finanzielle Vermögen** übernehmen
 - oder einen **Kredit aufnehmen**.

6

Technischer Angriff vs. Social Engineering

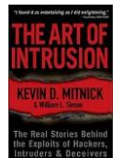


7

Wie funktioniert Social Engineering

Social Engineering ist ein vielschichtiger Angriff und umfasst:

- Der Täter **untersucht zunächst das beabsichtigte Opfer** und sammelt die notwendigen Hintergrundinformationen, wie z. B. potenzielle Eintrittspunkte und schwache Sicherheitsprotokolle, die für den Angriff erforderlich sind
- Der Angreifer versucht dann, das **Vertrauen des Opfers zu gewinnen**, und gibt Anreize für nachfolgende Aktionen, die etablierte Sicherheitspraktiken brechen, wie z. B. die Offenlegung sensibler Informationen und das Gewähren des Zugriffs auf kritische Ressourcen
- Social Engineering ist einfach das effizienteste, kostengünstigste und leistungsfähigste Werkzeug**, das von Cyberkriminellen bei so vielen verschiedenen Arten von Verbrechen eingesetzt wird



8

Was könnte ein Hacker mit den folgenden Informationen machen?

E-Mail-Konto	▪ Senden einer Phishing-E-Mail an Kontakte
Details zum Social-Media-Konto	▪ Sich als die Person ausgeben, um sich persönlich zu bereichern
Bankverbindung	▪ Geld ausgeben oder Kredite aufnehmen
Online-Geschäftsinformationen	▪ Drohung mit der Veröffentlichung von Informationen an die Öffentlichkeit
Personenbezogene Daten	▪ Verkaufen der Daten an Unternehmen; Identitätsdiebstahl
Zugriff auf Spielkonten und Videos	▪ Konto als Geisel halten
Geschichte des Online-Shoppings	▪ Verkaufen der Informationen an Unternehmen, damit diese ihre Werbung ausrichten können

Emotionen

Emotion	Beschreibung	Typische Anwendung im Angriff
Angst	Menschen reagieren impulsiv, wenn sie sich bedroht fühlen.	„Ihr Konto wurde gehackt – handeln Sie sofort!“
Neugier	Unerwartete oder interessante Informationen wecken Aufmerksamkeit.	„Sehen Sie, was Ihre Kollegen über Sie sagen!“
Gier	Aussicht auf Gewinn oder Vorteil kann zu unüberlegtem Handeln führen.	„Sie haben einen Gutschein gewonnen – klicken Sie hier!“
Vertrauen	Wird aufgebaut, um später ausgenutzt zu werden.	Ein Angreifer kommuniziert über Wochen freundlich, bevor er Zugang verlangt.
Mitleid	Menschen helfen gern, wenn jemand in Not ist.	„Ich bin neu und verstehe das System nicht – können Sie mir helfen?“
Druck/Stress	Zeitdruck oder Überforderung führen zu Fehlern.	„Ich brauche das sofort, sonst gibt es Konsequenzen!“
Scham	Angst, sich zu blamieren, verhindert kritisches Nachfragen.	„Sie wissen doch, wie das geht – oder etwa nicht?“
Stolz	Menschen wollen kompetent und hilfsbereit erscheinen.	„Nur Sie können mir helfen – Sie sind der Beste im Team!“
Unsicherheit	In unklaren Situationen wird schneller auf scheinbar kompetente Personen gehört.	„Ich bin vom Support – ich helfe Ihnen durch das Problem.“

Soziale Prinzipien

Prinzip	Beschreibung	Beispiel im Social Engineering
Autorität	Menschen neigen dazu, Anweisungen von Autoritätspersonen zu folgen.	Ein Angreifer gibt sich als IT-Leiter aus und fordert Passwortwechsel.
Knappheit	Etwas wird als wertvoller wahrgenommen, wenn es begrenzt verfügbar ist.	„Nur heute können Sie Ihr Konto retten – klicken Sie jetzt!“
Sympathie	Menschen helfen eher Personen, die sie mögen oder sympathisch finden.	Ein Angreifer baut über Social Media eine freundschaftliche Beziehung auf.
Reziprozität	Menschen fühlen sich verpflichtet, Gefälligkeiten zu erwidern.	„Ich habe Ihnen ein kostenloses Tool geschickt – könnten Sie mir dafür etwas zeigen?“
Konsistenz	Menschen wollen als konsequent wahrgenommen werden und handeln entsprechend.	„Sie haben doch letzte Woche gesagt, Sie helfen bei IT-Problemen – könnten Sie mir jetzt helfen?“
Soziale Bewährtheit	Menschen orientieren sich am Verhalten anderer, besonders in unsicheren Situationen.	„Alle Kollegen haben den Link schon geöffnet – du solltest das auch tun.“
Vertrauen	Vertrauen wird durch gezielte Kommunikation aufgebaut und dann ausgenutzt.	Ein Angreifer kommuniziert über Wochen freundlich, bevor er um Zugang bittet.
Dringlichkeit	Zeitdruck führt zu unüberlegten Entscheidungen.	„Sofort handeln, sonst wird Ihr Konto gesperrt!“

tgm [Quelle: Ciampa, Mark. CompTIA security+ guide to network security fundamentals. Cengage Learning, 2021.]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

11

11

QuickCheck - So erkennen Sie einen Social-Engineering-Angriff

1. Fühlen Sie sich in einer Situation ängstlich, unter Druck gesetzt oder sonst auf irgendeine Weise emotional aufgewühlt?

Manipulieren gezielt die menschlichen Emotionen, um ihre Opfer zu einer bestimmten Handlung zu bewegen.

2. Stammt die Nachricht von einem legitimen Absender oder einer Ihnen bekannten Person?

Um einen möglichen Betrug zu vermeiden, rufen Sie die Person oder das Unternehmen an oder geben Sie die Website-Adresse von Hand im Browser ein, anstatt auf einen Link zu klicken.

3. Kommt Ihnen auf der Webseite etwas verdächtig oder anders als sonst vor?

Wenn Sie zum Beispiel über einen Link auf die Website weitergeleitet wurden, überprüfen Sie, ob Ihnen der Link

verdächtig vorkommt. Um mögliche Unterschiede festzustellen, geben Sie die URL am besten von Hand ein.

4. Scheint das Angebot oder die Behauptung zu gut, um wahr zu sein?

Vielleicht wird Ihnen ein extrem hoher Gewinn geboten oder ein besserer Deal für ein Angebot, das Sie bereits nutzen. Scheint es zu gut, um wahr zu sein, dann ist es das wahrscheinlich auch. Falls Sie das Angebot nicht angefordert hatten, kontaktieren Sie die Organisation direkt, zur Klärung.

5. Kann die Person ihre Identität nachweisen?

Wurden Sie von jemandem kontaktiert, der Ihre Hilfe benötigt oder bei einer Organisation angestellt ist, mit der Sie im Geschäft sind? Lassen Sie sich die Identität von einem Dritten bestätigen oder setzen Sie sich selbst direkt mit der Organisation in Verbindung.

tgm [Quelle: <https://sosafe-awareness.com/de/glossar/social-engineering/> - letzter Abruf 29.10.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

12

12

Übliche Social Engineering Attacken

Personifikation

- Maskerade als reale oder fiktive Figur
- Ausspielen der Rolle dieser Person an einem Opfer
- Zu den nachgeahmten Parteien gehören der IT-Support, der Manager und der vertrauenswürdige Dritte

Phishing

- Versenden von (Millionen) E-Mails, die angeblich von einer legitimen Quelle stammen
- Verleiten Sie den Benutzer dazu, private Informationen preiszugeben: Passwort, Kreditkartennummer usw.

Variationen von Phishing-Angriffen

- Pharming: leitet den Benutzer automatisch auf die gefälschte Seite weiter
- Spear-Phishing: zielt nur auf bestimmte Benutzer ab; E-Mails werden angepasst
- Whaling: Spear-Phishing, das auf "große Fische" (wohlhabende Personen) abzielt
- Vishing: Statt per E-Mail kann stattdessen ein Telefonanruf genutzt werden (Voice-Phishing)



[Quelle: Ciampa, Mark. CompTIA security+ guide to network security fundamentals. Cengage Learning, 2021.]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

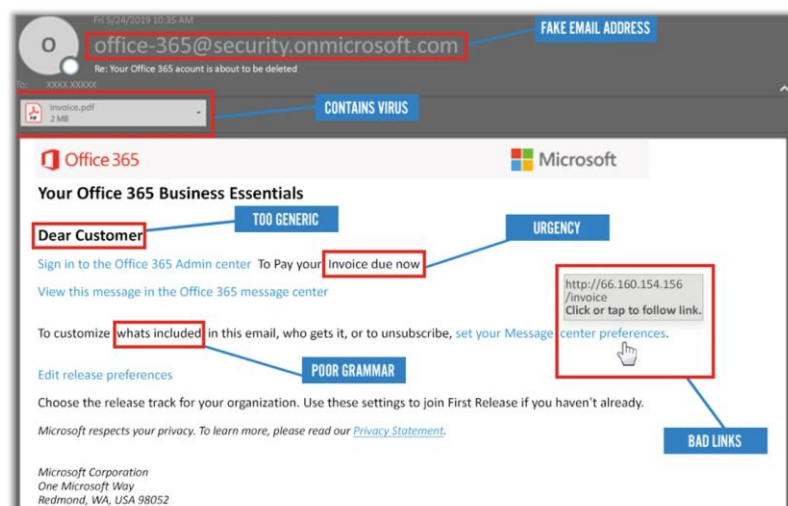
13

13

Phishing Mails

Phishing-E-Mails sind schwer von legitimen E-Mails zu unterscheiden

Der Angreifer verwendet Logos und Farben, die mit denen einer legitimen Entität identisch sind



[Quelle: <https://www.newcmi.com/blog/tips-for-detecting-a-phishing-email> - letzter Abruf 29.10.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

14

14

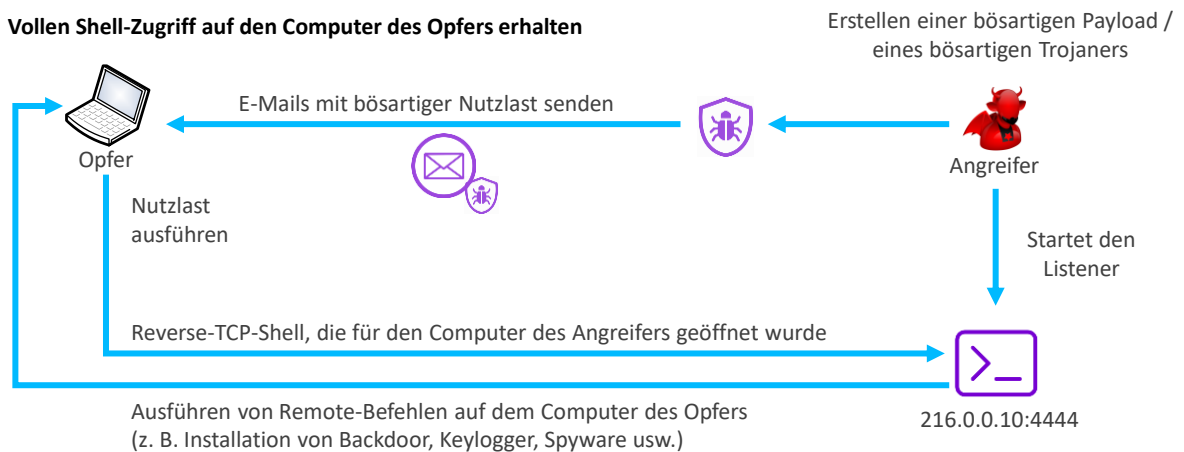
Sammeln von Anmeldeinformationen



15

Reverse Shell

Der Angreifer stellt eine Verbindung vom Opfer zum eigenen System her
Vollen Shell-Zugriff auf den Computer des Opfers erhalten



16

Übliche Social Engineering Attacken

- Disruptionware
- Ransomware
- Cyber-Wiper
- Malware
- Kompromittierung von Geschäfts-E-Mails
- Wirtschaftsspionage
- Daten-Sniffer
- Monitor für Tastaturanschläge
- Hintertüren in das Netzwerk
- Diebstahl von geschäftlichen E-Mails
- Diebstahl von geistigem Eigentum (IP)
- Diebstahl von personenbezogenen Daten von Mitarbeitern (PII)

Gefährliche Inhalte in sozialen Netzwerken – Was Sie besser nicht teilen sollten

Kalender, Reisepläne und Ortsangaben

- **Gefahr:** Virtuelle Entführungen, Einbrüche, CEO-Fraud.
- **Beispiele:** Hochzeitseinladungen → Ziel für virtuelle Entführung / Urlaubsankündigungen → Einladung für Einbrecher / Flugdetails → Betrüger geben sich als Sie aus und manipulieren Kollegen.
- **Tipp:** Reiseinformationen niemals im Voraus posten.

Finanzinformationen

- **Gefahr:** Phishing, Vishing, Smishing, Kontozugriffe.
- **Beispiele:** Kreditkartennummern oder Bankbesuche öffentlich teilen / Informationen über Investitionen (Aktien, Krypto etc.) → Ziel für Cyberangriffe / Anlageempfehlungen → Risiko rechtlicher

Konsequenzen

- **Tipp:** Finanzdaten und -aktivitäten niemals öffentlich machen.

Persönliche Informationen

- **Gefahr:** Identitätsdiebstahl, Beantwortung von Sicherheitsfragen durch Dritte.
- **Beispiele:** Familienmitglieder im Profil verlinken → Geburtsname der Mutter / Wohnort etc / Angaben wie: Zweiter Vorname des Vaters / Geburtstag der Mutter / Ort des Kennenlernens / Lieblingsurlaubsziel / Erste Schule, Straße der Kindheit / Lieblingssessen/-getränk
- **Tipp:** Diese Daten sind oft Antworten auf Sicherheitsfragen – nicht öffentlich teilen!

Gefährliche Inhalte in sozialen Netzwerken – Was Sie besser nicht teilen sollten

Informationen über Kinder

- **Gefahr:** Entführung, Missbrauch, Einbruch.
- **Beispiele:** Fotos mit Geotags oder Zeitstempeln → Rückschlüsse auf Aufenthaltsorte / Namen von Schulen, Vereinen, Kindergärten → Ziel für Pädophile oder Einbrecher / Muster im Tagesablauf → Planung von Angriffen möglich.
- **Tipp:** Keine Details zu Aufenthaltsorten, Aktivitäten oder Reisen von Kindern posten.

Informationen über Haustiere

- **Gefahr:** Missbrauch als Antwort auf Sicherheitsfragen.
- **Beispiel:** Name des ersten Haustiers → häufige Sicherheitsfrage.

- **Tipp:** Auch scheinbar harmlose Infos wie Tiernamen können gefährlich sein.

Berufliche Informationen

- **Gefahr:** Angriffe auf Unternehmen, gezielte Phishing-Versuche
- **Beispiele:** Technologien am Arbeitsplatz → Hinweise auf Schwachstellen / Virus-Hoaxes und Fake-Warnungen → Panikmache und Verbreitung von Falschinformationen / Prahlen mit Verkehrsverstößen → rechtliche und berufliche Konsequenzen.
- **Tipp:** Berufliche Details nur mit Bedacht teilen, keine Gesetzesverstöße öffentlich machen.

Gefährliche Inhalte in sozialen Netzwerken – Was Sie besser nicht teilen sollten

Medizinische und juristische Ratschläge

- **Gefahr:** Rückschlüsse auf Krankheiten oder Rechtsstreitigkeiten.
- **Beispiele:** Wenn Sie medizinische Tipps geben, könnten andere vermuten, dass Sie oder ein Angehöriger betroffen sind / Juristische Kommentare können den Eindruck erwecken, dass Sie in einen Rechtsstreit verwickelt sind.
- **Risiko:** Kriminelle nutzen diese Informationen, um gezielt emotionale Manipulation oder Betrug zu betreiben.
- **Tipp:** Fachliche Ratschläge nur in geschützten, professionellen Kontexten teilen.

Standortinformationen

- **Gefahr:** Virtuelle Entführungen, Einbrüche, gezielte Angriffe.
- **Beispiele:** Standortfreigabe in Echtzeit → zeigt, dass Sie nicht zu Hause sind / Bilder von religiösen, politischen oder kulturellen Orten → Rückschlüsse auf Zugehörigkeit / Öffentliche Geburtstagsglückwünsche → Preisgabe des echten Geburtsdatums.
- **Tipp:** Standort nur mit vertrauenswürdigen Personen teilen, keine Echtzeit-Posts.

Zusätzliche Hinweise zur Prävention

- Privatsphäre-Einstellungen regelmäßig prüfen.
- Beiträge vor dem Posten hinterfragen: Könnte jemand diese Information missbrauchen?
- Keine sensiblen Daten öffentlich machen, auch nicht indirekt.
- Vermeiden Sie Muster: Wiederholte Posts zu bestimmten Zeiten oder Orten können analysiert und ausgenutzt werden.

FAZIT

- Jede Information, die online geteilt wird, kann von Kriminellen missbraucht werden.
- Immer daran denken: Weniger ist mehr.
- Sensible Daten niemals öffentlich posten.

Falsche Kontakte in den sozialen Netzwerken

Ungewöhnliches oder fehlendes Profilbild

- Stockfotos oder Modelbilder: Häufig übermäßig attraktive Personen, oft aus Bilddatenbanken.
- Gestohlene Bilder: Von echten Profilen kopiert – besonders gefährlich, da sie authentisch wirken.
- Keine Bilder: Ein leeres Profilbild oder nur ein Emoji/Karikatur kann ebenfalls verdächtig sein.
- Tipp: Verwende eine Bilderrückwärtssuche (z. B. Google Lens), um zu prüfen, ob das Bild auf anderen Seiten auftaucht.

Fehlende oder fragwürdige Verifizierung

- Öffentliche Personen ohne Verifizierung: Wenn ein angeblicher Prominenter oder Experte kein blaues Häkchen hat, ist Skepsis angebracht.
- Verifizierungszeichen gefälscht: Manche Betrüger fügen das Symbol manuell ins Profilbild ein – das ist kein echtes Verifizierungsmerkmal.

Falsche Kontakte in den sozialen Netzwerken

Unlogische oder unpassende gemeinsame Kontakte

- Wenig oder keine gemeinsamen Freunde: Besonders bei beruflichen Netzwerken wie LinkedIn auffällig.
- Gemeinsame Kontakte ohne Zusammenhang: Wenn die gemeinsamen Freunde aus verschiedenen Ländern stammen und sich untereinander nicht kennen.
- Tipp: Prüfe, ob die gemeinsamen Kontakte glaubwürdig sind oder selbst fragwürdige Profile haben.

Unrealistische oder widersprüchliche Profilinformationen

- Berufliche Angaben passen nicht zum Netzwerk: Z. B. ein „CEO“ mit nur 5 Kontakten auf LinkedIn.
- Unklare oder generische Jobtitel: „Business Consultant“, „Investor“, „Entrepreneur“ ohne konkrete Angaben.
- Fehlende Ausbildung oder Berufserfahrung: Keine Historie, keine nachvollziehbaren Stationen.

Falsche Kontakte in den sozialen Netzwerken

Fehlende oder untypische Beiträge

- Keine Inhalte zur angeblichen Tätigkeit: Z. B. ein Journalist ohne geteilte Artikel.
- Nur geteilte Memes oder allgemeine Motivationssprüche: Keine persönliche Note.
- Unregelmäßige Aktivität: Ein Profil, das plötzlich aktiv wird, nachdem es lange inaktiv war.

Sprachliche Auffälligkeiten

- Ungewöhnliche Sprache oder Grammatikfehler: Besonders bei angeblich deutschsprachigen Profilen.
- Automatisiert wirkende Nachrichten: Standardisierte Begrüßungen oder Copy-Paste-Texte.
- Tipp: Achte auf die Tonalität – wirkt die Kommunikation persönlich oder generisch?

Falsche Kontakte in den sozialen Netzwerken

Dringlichkeit oder emotionale Manipulation

- Schnelle Vertrauensbildung: „Ich habe dein Profil gesehen und finde dich sehr interessant.“
- Bitten um Hilfe oder Geld: Oft nach kurzer Zeit, z. B. „Ich bin in einer Notlage.“
- Emotionale Geschichten: Krankheit, Unfall, familiäre Probleme – oft erfunden, um Mitleid zu erzeugen.

Technische Auffälligkeiten

- Profil wurde kürzlich erstellt: Wenig Aktivität, kaum Inhalte.
- Ungewöhnlicher Benutzername: Z. B. Kombinationen aus Zahlen und Buchstaben oder fremdsprachige Namen ohne Bezug.
- Mehrere ähnliche Profile: Gleiche Bilder, aber unterschiedliche Namen – ein Hinweis auf Massenbetrug.

Falsche Kontakte in den sozialen Netzwerken

Zusätzliche Tipps zur Erkennung

- Vergleiche mit anderen Plattformen: Gibt es das Profil auch auf Xing, LinkedIn, Instagram?
- Frage dich: Würde diese Person mich wirklich kontaktieren? Im Zweifel: Nicht annehmen, sondern melden.

Recap: Richtiges Verhalten

1. Verwenden von sicheren und auch unterschiedlichen Passwörtern
2. Aktivieren der 2-Faktor-Authentifizierung (2FA)
3. Vorsichtiges klicken auf Links in E-Mails oder Nachrichten.
4. Vermeiden der Weitergabe von persönlichen Daten.
5. Vorsichtige Online-Freundschaften.
6. Speichern von Passwörtern mit einem Browser oder einem Passwort-Manager(bevorzugt)
7. Sichern von Daten
8. Aktualisieren von Geräten



[Quelle: <https://www.spiceworks.com/it-security/vulnerability-management/articles/what-is-social-engineering/> - letzter Abruf 29.10.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

27

27

02

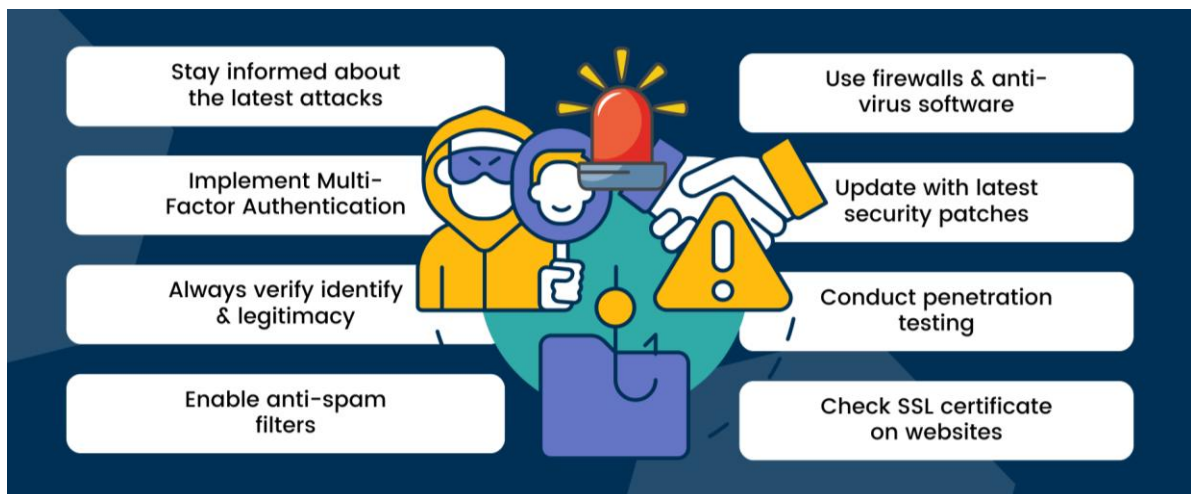
(Technische) Social Engineering Abwehr

28

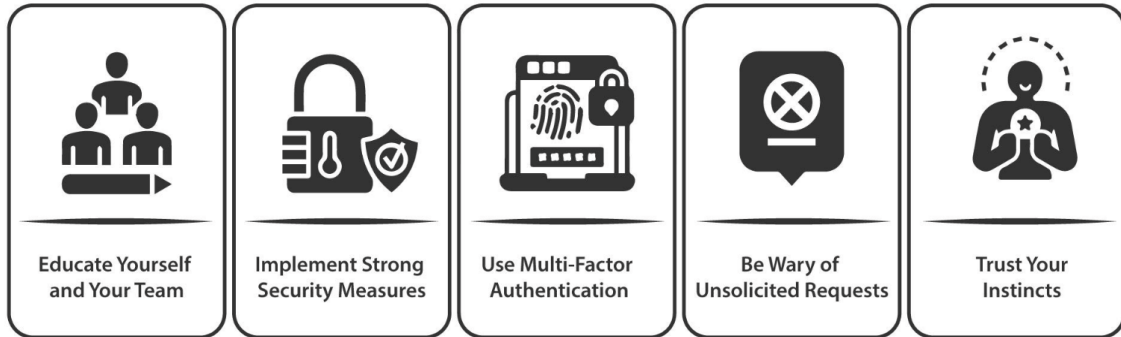
Was Social Engineering Angreifer wissen

- Es gibt eine Menge **Unternehmensinformationen**, mehr als man denkt
- Es gibt eine Menge **persönlicher Informationen**, mehr als man denkt
- Die Sicherheit ist an **Verbindungspunkten** sehr anfällig
- Sicherheit ist in **Ausnahmeprozessen** sehr anfällig
- Es ist einfach, (viele) E-Mails als **jede andere Person/Organisation** zu versenden
- Es ist einfach, **jemanden anzurufen**, der scheinbar von einer beliebigen Nummer kommt
- In größeren Unternehmen kennen sich die meisten Menschen nicht, aber **jeder möchte helfen**
- Social-Engineering-Ansätze: **Go-Big oder Go-Targeted**
- Die meisten Menschen **meiden erweiterte Sicherheit**, weil "es schwierig ist"

Effektive Gegenmaßnahmen gegen Social-Engineering-Angriffe



Was sind die Strategien, um Social Engineering zu verhindern?



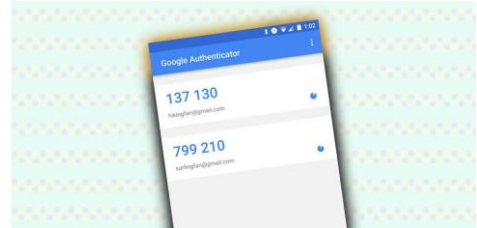
So kann die Sicherheitslage verbessert werden



Abwehr/Block von Social Engineering

Multi-Factor Authentication (MFA)

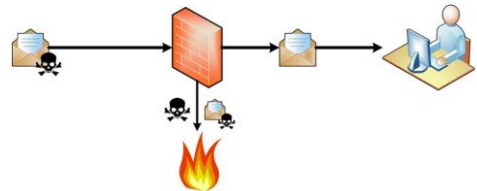
- Im Allgemeinen sind Passwörter nicht gut genug
- Wenn Sie verwendet werden müssen: Die Länge ist der wichtigste Faktor!
- MFA = die effektivste Abschwächung



Abwehr/Block von Social Engineering

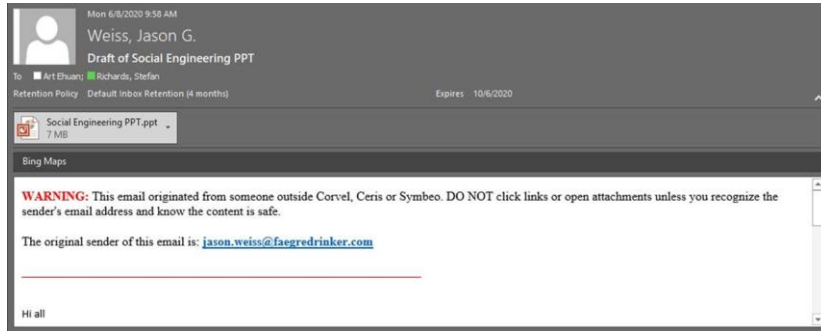
Inbound Filtering (Email Gateways)

- Stoppt oder "bereinigt" problematische E-Mails, bevor sie Sie erreichen
- Nutzung von Reputations- und kollektiven Bedrohungsinformationen
- Lernt von anderen Benutzern, die gefährliche E-Mails melden
- Authentifizierung von Absendern – DMARC



Abwehr/Block von Social Engineering

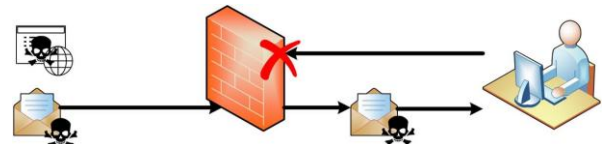
Email Banners



Abwehr/Block von Social Engineering

Outbound Filtering (Firewalls, Proxies)

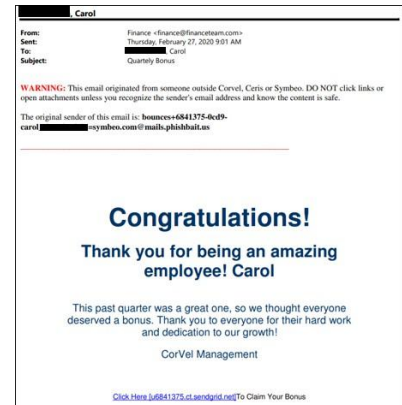
- Blockieren Sie den Klick!
- Stoppt den Datenverkehr in "schlechte Nachbarschaften" im Internet
- Sucht nach und stoppt Malware beim Ruf nach Hause (Command and Control)
- Überwacht ausgehenden Datenverkehr auf wahrscheinliche Exfiltration
- Nutzung von Reputations- und kollektiven Bedrohungsinformationen
- Automated Phish Tests
- Cyber Hygiene



Abwehr/Block von Social Engineering

Automated Phish Tests

- Automatisieren für die Skalierung
- Testen mehrmals pro Jahr
- Anpassen an aktuelle Bedrohungen
- Alle Mitarbeiter, insbesondere risikobehaftete Abteilungen testen
- Bezug auf Schulungen mittels Knopfdruck
- Sammeln von Metriken, um kontinuierliche Sensibilisierungsbemühungen zu unterstützen



Abwehr/Block von Social Engineering

Cyber Hygiene

- Nur aktuell unterstützte Software verwenden
- Frühes und oftmaliges Patchen
- Entfernen nicht benötigter Software und Dienste
- Nicht als Administrator ausführen
- Implementieren und testen von regelmäßigen Backups
- Regelmäßiges Überprüfen und testen der Sicherheitslage
- Erweiterten Anti-Malware-Schutz in Betracht ziehen



03

Social Engineering Awareness

39

IT-SICHERHEIT / SEMESTER 1 UND 2

The most common delivery methods and cybersecurity vulnerabilities causing ransomware infections worldwide*



secureframe

*According to MSPs: Source: Statista

tgm

[Quelle: <https://secureframe.com/blog/social-engineering-statistics> - letzter Abruf 29.10.2025]

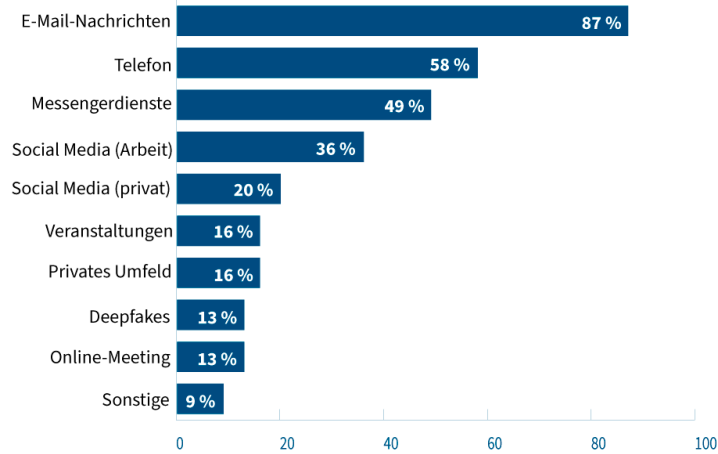
tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

40

40

KANÄLE FÜR SOCIAL-ENGINEERING-ANGRIFFE AUF KMU

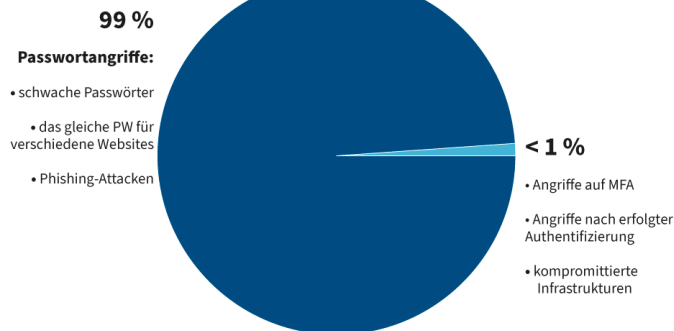
Über welche Kommunikationswege erfolgten 2024 Social-Engineering-Attacks?



Quelle: Cybersecurity in Österreich, KPMG-Studie 2024

ANGRIFFE AUF DIGITALE IDENTITÄTEN/BENUTZERKONTEN

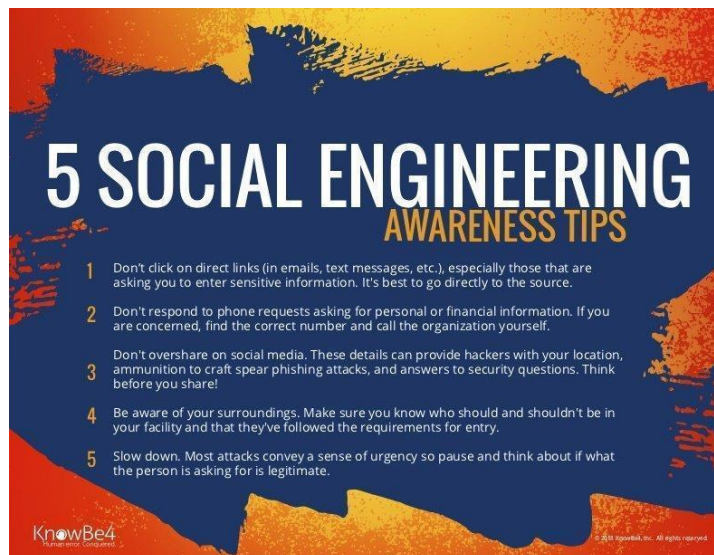
Die dominanteste Angriffsmethode auf digitale Identitäten sind Passwortangriffe (Stand: 2024)



Quelle: Microsoft Digital Defense Report 2024

Gründe für menschliches Fehlverhalten in der IT-Sicherheit

- **Mangelndes Risikobewusstsein** - Viele Menschen unterschätzen die Risiken, die von unsicheren Passwörtern, nicht aktualisierter Software oder dem Herunterladen unbekannter Anhänge ausgehen. Ein fehlendes Bewusstsein für Cybergefahren führt dazu, dass grundlegende Schutzmaßnahmen ignoriert werden und Einfallstore für Cyberangriffe entstehen.
- **Unachtsamkeit** - Menschliche Fehler wie das Versenden von E-Mails an falsche Empfänger, das Öffnen infizierter Anhänge oder das Konfigurieren von Systemen mit falschen Sicherheitseinstellungen sind häufige Ursachen für Sicherheitsvorfälle. Selbst erfahrene Userinnen und User sind vor Flüchtigkeitsfehlern nicht gefeit.
- **Mangelnde Awareness in Unternehmen**. Ein großes Risiko für die Cybersicherheit eines Unternehmens besteht, wenn zum Beispiel interne IT-Richtlinien aus mangelndem Bewusstsein für die möglichen Konsequenzen umgangen werden. In selteneren Fällen können auch unzufriedene Mitarbeiterinnen und Mitarbeiter in voller Absicht sensible Daten an Dritte weitergeben.



Wichtige Themen einer Cybersicherheitsschulung

Hier sind vier wichtige Themen, die in jedem Sicherheitstraining behandelt werden sollten.



Phishing-Angriffe

Phishing gehört zu den ältesten und immer noch effektivsten Angriffsmethoden. Geschulte Mitarbeiter sind ein wichtiger Faktor, um dieser Bedrohung zu begegnen und richtig damit umzugehen.



Social-Engineering-Angriffe

Social-Engineering-Angriffe finden nicht nur per E-Mail statt. Ursprung kann ein Telefonanruf, ein Gespräch oder einfach auch nur der Nachbarschreibtisch sein. Anwender müssen lernen, ihre Aufmerksamkeit für alle Angriffsmöglichkeit zu schärfen.



Passwort-Hygiene

Das Thema-Passwort-Sicherheit ist ein Bereich, der seit jeher viele Risiken birgt. Wenn die Mitarbeiter Passwortmanager verwenden und sich bewusst sind, stets verschiedene Passwörter für unterschiedliche Dienste zu verwenden, stärkt dies die Sicherheit.



Sichere Fernarbeit

Das Thema Remote Work hat signifikant an Bedeutung gewonnen. Solide Richtlinien im Hinblick auf die Speicherung von und den Zugriff auf sensible Daten müssen durchgesetzt und von den Mitarbeitern verinnerlicht werden.